

Cybersecurity General Terms & Definitions

Full name: Jamere Golden

Please provide **short concise** definitions/explanations for each of the cybersecurity terminologies. Each definition/explanation entry is worth **5** points.

Direction & Submission: use the downloaded document, provide the definition/explanation for each indicated row term below. At the completion, submit the completed document through Canvas. You have up to **a week** to submit the assignment after the due date. Please note that there is a daily **5%** deduction *if submitted after the due date*.

	Terms	Definition/explanation
1	Security Vs Convenience	Security involves measures like strong passwords, encryption, and multi-factor authentication to prevent unauthorized access, but these can frustrate users. Convenience prioritizes ease of use through features like single sign-on or minimal password requirements but can introduce vulnerabilities.
2		a. Confidentiality: to keep confidential to unauthorized individuals. b. Integrity: to preserve data integrity—data should not be altered by unauthorized individuals or other devices. c. Availability: keep data available to authorized users with the least privileges or access.
3	Authentication, Authorization, & Accounting (AAA)	a. Authentication: is the process of verifying an identity claim, typically using credentials like passwords, biometrics, or security tokens. b. Authorization: is the process of determining what actions, resources, or services a verified user or system is permitted to access. c. Accounting: is the process of tracking and recording user activities, resource usage, or system events for

		<i>auditing, monitoring, and reporting purposes.</i>
4	Identification	identification is the act of claiming an identity to a system, such as providing a username or ID, as the first step before authentication.
5	Security Control	is a safeguard or measure implemented to protect systems, data, and networks from threats, reduce risks, or ensure compliance with policies.
6	Managerial	are policies, procedures, and guidelines established by an organization to manage and oversee security practices, ensuring compliance and risk management.
7	Operational	day-to-day procedures and practices used to protect systems, detect threats, and ensure ongoing security
8	Technical	are security measures used through technology, such as firewalls, encryption, access controls, and intrusion detection systems, to protect systems and data.
9	Physical	are measures that protect hardware and facilities from physical threats, such as locks, security guards, and surveillance cameras.
10	Deterrent Control	is a measure designed to discourage potential attackers from attempting unauthorized actions
11	Preventive Control	is a measure implemented to stop security breaches before they occur
12	Detective Control	is a measure designed to identify and alert on security incidents or breaches
13	Compensating Controls	are alternative measures implemented to mitigate risks when primary controls are not effective
14	Corrective Control	is a measure taken to rectify or recover from a security breach or incident
15	Directive Control	is a measure that provides guidance or instructions to influence behavior,

16	Incentive Control	is a measure designed to motivate desired behaviors by offering rewards or benefits
17	Threat Actor/Malicious Actor/attacker	refers to an individual or group that attempts to exploit vulnerabilities in a system, network, or application to cause harm, steal data, or disrupt services.
18	Hacker	is an individual who gains unauthorized access to systems or networks, often to exploit vulnerabilities or weak areas in a system
19	White Hat Hacker/ Ethical hacker	is an individual who uses their hacking skills for legitimate purposes
20	Data exfiltration	is the unauthorized transfer or theft of data from a system or network, typically by an attacker, with the intent to misuse or sell the info.
21	Service Disruption	is an event or attack that causes a system, network, or service to become unavailable or operate incorrectly
22	Shadow IT	refers to the use of unauthorized devices, software, or applications within an organization, often by employees
23	Organize Crime	refers to coordinated groups or syndicates engaging in cybercrime activities, such as data theft, ransomware attacks, or financial fraud, for monetary gain or other illicit purposes.
24	Insider Threat	<i>is a security risk that comes from within an organization, typically involving employees, contractors, or partners who intentionally or unintentionally compromise systems, data, or processes.</i>
25	Hacktivists	is an individual or group that uses hacking techniques to promote a political, social, or ideological agenda, often through activities like website defacement, data leaks, or denial-of-service attacks.

26	Nation-state actors	are government-backed entities or individuals that carry out cyberattacks to achieve political, economic, or military objectives
27	Advanced Persistent Threats (APTs)	are sophisticated, long-term cyberattacks carried out by skilled threat actors, often nation-states or organized groups, targeting specific entities to steal data
28	Competitors	can pose a threat when they engage in unethical or illegal activities
29	Brokers	are individuals or groups who buy and sell stolen data, vulnerabilities, or exploits, often acting as intermediaries between attackers and buyers on black markets
30	Cyberterrorists	are individuals or groups that use cyberattacks to create fear, disrupt critical infrastructure, or advance political, religious, or ideological agendas
31	Attack Surface/Threat Vector	refers to all the possible points where an attacker could exploit a system's vulnerabilities, while a threat vector is the specific method or pathway an attacker uses to carry out an attack
	Mainstream Attack Surfaces	
32	Software (<i>vulnerable software</i>)	refers to programs or applications with weaknesses, bugs, or misconfigurations that attackers can exploit to compromise systems
33	Software (<i>file-based</i>)	refers to programs that interact with files for data storage, processing, or execution. software can be vulnerable if files are not properly secured, allowing attacks like malware or data exfiltration.
34	Software (<i>image-based</i>)	refers to programs that use image files (such as JPEG, PNG, or GIF) for processing, storage, or display. These applications can be vulnerable if they don't properly handle image file formats
35	Hardware (<i>Unsupported systems and applications</i>)	refers to devices or systems that no longer receive updates or support from manufacturers, making them vulnerable to security threats.

36	Hardware (<i>removable devices</i>)	refers to portable storage devices like USB drives, external hard drives, or SD cards, which can be easily connected to different systems
37	Network (<i>unsecured networks</i>)	refers to networks that lack proper security measures, such as encryption, firewalls, or access controls.
38	Network (<i>open service ports</i>)	<i>network ports that are left open on a device or server, allowing external access to specific services or applications.</i>
39	Network (<i>default credentials</i>)	factory-set usernames and passwords that come with devices or systems. If not changed, these default credentials can be easily exploited by attackers to gain unauthorized access
	Communications	
40	Email	communication method that can be exploited by attackers through techniques like phishing, malware attachments, or spoofing.
41	Texts (<i>Short Message Service (SMS)</i>)	short messages sent via mobile networks. SMS can be exploited in attacks like phishing (smishing), two-factor authentication bypass, or malware distribution
42	<i>Instant Messaging (IM)</i>	real-time text communication through platforms like WhatsApp, Facebook Messenger, or Slack. IM can be targeted by attackers through similar tactics as sms
43	Voice Calls	communication over telephony networks, which can be exploited through attacks like vishing (voice phishing)
44	Supply Chain	
45	manufacturing	the processes and systems used in the production of hardware and software.
46	storage	systems and devices used to store data, such as hard drives, cloud storage, or databases.

47	distribution	refers to the process of delivering software, data, or services to end users or systems.
48	Supply chain infections	refer to cyberattacks that target vulnerabilities in the supply chain, such as compromising software updates, hardware components, or service providers.
	Vulnerabilities	
49	Vulnerability	<i>refers to a weakness or flaw in a system, software, or hardware that can be exploited by attackers to gain unauthorized access, disrupt operations, or steal sensitive data.</i>
50	OS-based vulnerabilities	weaknesses or flaws in an operating system that can be exploited by attackers and it can be the OS's code, configuration, or management features, leaving systems open to attacks like privilege escalation, malware, or remote exploitation.
51	Application vulnerabilities	vulnerabilities may arise from coding errors, poor configuration, or design flaws in the application, leading to risks like SQL injection, cross-site scripting (XSS), or buffer overflows.
52	Malicious update	software or system update that has been tampered with by attackers to introduce malware, vulnerabilities, or backdoors.
53	Firmware	refers to the specialized software embedded into hardware devices that controls their functions.
54	Legacy Platforms	refer to outdated hardware, software, or systems that are still in use but no longer receive regular updates or support from manufacturers.
55	End-of-Life (EOL) Hardware	refers to devices that are no longer supported or manufactured by the vendor.refers to devices that are no longer supported or manufactured by the vendor.
	EOL Risk	

56	• Lack of security updates	the failure to regularly apply patches or updates to software, operating systems, or devices.
57	• High cost of maintenance	the significant expenses associated with keeping outdated or legacy systems and hardware secure and operational.
58	• Loss of comprehensive security	weakening or absence of a holistic security approach that covers all aspects of a system, including network, data, application, and physical security.
59	• Legal implications	the potential legal consequences of security breaches, data theft, or non-compliance with regulations
60	Misconfigurations	errors or mistakes made during the setup or configuration of systems, applications, or networks that can lead to security vulnerabilities.
61	• Default settings	are the pre-configured options set by manufacturers or software developers when a system, application, or device is first installed.
62	• Open ports and services	refer to network ports and associated services that are exposed to external connections.
63	• Unsecured root accounts	refer to administrative accounts (often with full system access) that lack proper security measures, such as strong passwords or multi-factor authentication.
64	• Open permissions	settings that allow excessive access to files, directories, or systems, often granting read, write, or execute rights to unauthorized users or groups.
65	• Unsecured protocols	communication protocols that lack encryption or authentication mechanisms
66	• Weak encryption	encryption methods that can be easily broken or compromised due to insufficient key lengths, outdated algorithms, or poor implementation.

67	Errors	refer to mistakes, flaws, or bugs in software, systems, or configurations that can create vulnerabilities
68	Zero-Day vulnerability	is a security flaw in software or hardware that is unknown to the vendor or the public and has no available fix or patch.
	Impacts of Attacks	
69	Data loss	refers to the unintended destruction, corruption, or theft of data, making it unavailable or unrecoverable.
70	Data exfiltration	is the unauthorized transfer of sensitive data from a system or network to an external location, often by malicious actors.
71	Data breach	occurs when unauthorized individuals gain access to sensitive or confidential data, often leading to its exposure, theft, or loss.
72	Identity theft	is the fraudulent acquisition and use of someone else's personal information, typically for financial gain.
73	Availability loss	refers to the unintentional or intentional disruption of access to systems, services, or data.
74	Financial loss	in computer security refers to the monetary damage caused by security incidents, such as data breaches, cyberattacks, or fraud.
	Security framework	
75	Security Framework	is a structured set of guidelines, best practices, and standards designed to help organizations manage and improve their security posture.
76	National Institute of Standards and Technology (NIST)	is a U.S. government agency that develops and promotes measurement standards, including guidelines and frameworks for cybersecurity.
	NIST Core Elements, Implementations and Profiles	

77	Functions (<i>element</i>)	The Functions element of the NIST Cybersecurity Framework consists of five key activities: Identify, Protect, Detect, Respond, and Recover, which guide organizations in managing cybersecurity risks
78	Categories (<i>element</i>)	The Categories element in the NIST Cybersecurity Framework is a subset of the five core functions and provides more specific cybersecurity objectives within each function.
	Subcategories(<i>element</i>)	The Subcategories element in the NIST Cybersecurity Framework further breaks down the Categories into more detailed and actionable components.
79	Information sources (<i>element</i>)	The Information Sources element in the NIST Cybersecurity Framework refers to the resources, data, and tools that organizations rely on to support their cybersecurity activities.
80	Implementation Tiers	The Implementation Tiers in the NIST Cybersecurity Framework represent the maturity level of an organization's cybersecurity practices. These tiers range from Tier 1 (Partial) to Tier 4 (Adaptive)
81	Profiles	Profiles in the NIST Cybersecurity Framework are customized cybersecurity strategies tailored to an organization's specific business needs, risk tolerance, and resources.
	<i>The two widely used NIST framework</i>	
82	Risk Management Framework	is a structured approach used to manage and mitigate risks in an organization's information systems.
83	Cybersecurity Framework	The Cybersecurity Framework developed by NIST is a set of guidelines and best practices designed to help organizations manage and reduce cybersecurity risks
	Provide a framework and description for each of the followings	

84	International Organization for Standardization (ISO)	<i>The International Organization for Standardization (ISO) provides a series of globally recognized standards that help organizations establish, implement, and maintain effective cybersecurity and information security practices. A key standard within ISO related to cybersecurity is ISO/IEC 27001, which focuses on Information Security Management Systems (ISMS).</i> <i>Framework: ISO/IEC 27000 series provides a range of international standards for information security, with ISO/IEC 27001 focusing on establishing, implementing, and maintaining Information Security Management Systems (ISMS). Other related standards, such as ISO/IEC 27002 for security controls, ISO/IEC 27005 for risk management, and ISO/IEC 27017 for cloud security, offer detailed guidance on managing risks, securing personal data, and protecting sensitive information across various industries.</i>
85	American Institute of Certified Public Accountants	is a professional organization that sets standards for accounting and auditing practices in the U.S., as well as for cybersecurity and risk management. It provides guidance on cybersecurity risks through the AICPA Cybersecurity Risk Management Framework, which helps organizations assess and manage cybersecurity risks, ensuring they have adequate controls to protect sensitive information and systems.
	Regulations	
86	Regulatory compliance	refers to the adherence to laws, regulations, and standards set by government bodies, industry organizations, or other authoritative entities to ensure that businesses operate within the legal and ethical boundaries

87	Industry regulations by:	
88	Name the four regulatory bodies for <i>information security</i> listed in the textbook	National Institute of Standards and Technology (NIST) International Organization for Standardization (ISO) European Union Agency for Cybersecurity (ENISA) Federal Trade Commission (FTC)
89	Legislation	refers to laws and legal requirements enacted by governments to regulate various aspects of society, including cybersecurity and information security.
90	A standard	is a set of established guidelines, rules, or specifications that define the requirements for products, services, or systems to ensure consistency, quality, and safety.
91	Payment Card Industry Data Security Standard (PCI DSS)	s a set of security standards designed to ensure that all organizations handling credit card information maintain a secure environment.
92	Benchmarks/Security configuration guides	are comprehensive documents that provide specific security configuration recommendations to harden systems, networks, and applications against potential vulnerabilities.
93	Information Sources for cybersecurity (<i>List a few</i>)	Threat Intelligence Feeds Security Blogs and Websites National Institute of Standards and Technology (NIST) CERTs (Computer Emergency Response Teams)